CARLOS GABRIEL GOMES LUZ

APPLICATION SECURITY (APPSEC) | DEVSECOPS | SOFTWARE ENGINEERING

São Paulo, SP | +55 (11) 96762-2665 | carlosgabriel.contato2007@gmail.com
linkedin.com/in/dev-carlosgabriel | github.com/CarlossgLuz | carlosg.com.br

PROFESSIONAL SUMMARY

Junior Systems Development Analyst with practical experience in AppSec, ASPM, and DevSecOps, pursuing a career in application security. Contributing to XGuardian through vulnerability analysis, software supply chain security, RBAC, metrics, and automation. I also develop independent API security and AI agent governance projects, combining Python, testing, execution policies, and traceability.

PROFESSIONAL EXPERIENCE

Xmart Solutions | Santo André, SP, Brazil

Junior Systems Development Analyst | Jun/2026 – Present

- Contributed to the evolution of XGuardian, a SaaS AppSec and ASPM platform, enhancing features and SAST, SCA, DAST, Container Security, and SBOM reports to improve the visualization and contextualization of security findings.
- Developed and enhanced dashboards, metrics, filters, and vulnerability analysis workflows, including scan quota controls by application and team, with an emphasis on data consistency and operational usability.
- Investigated and contextualized vulnerabilities and dependencies using references such as OWASP Top 10, NIST NVD, MITRE CVE/CWE, CVSS, and the GitHub Advisory Database, also considering component end-of-life (EOL).
- Participated with the team in assessing and developing role-based access control (RBAC), covering roles, permissions, access segregation, and protection of platform operations and APIs.
- Provided technical assistance and support for the Sonatype ecosystem, documentation, and enterprise environment troubleshooting, including a financial-sector deployment intended for hundreds of developers. Also participated in vendor technical meetings conducted in English. Xmart Solutions is currently a Brazilian Sonatype partner with multiple professionals trained and qualified in implementing and supporting its ecosystem.
- Participated in the technical partnership between Xygeni and Xmart Solutions, with platform access, specialist-led training, and evaluation of AppSec and software supply chain security capabilities.
- Used Semgrep, OWASP ZAP, Gitleaks, and Dependabot in studies and validations.
- Applied generative AI workflows and automation to engineering and security activities, integrating models, agents, and tools via APIs and MCP to support technical analysis, documentation, QA, and controlled workflow execution, with attention to permissions and data protection, managing overall agent governance and auditing decisions.

Systems Development Intern | Dec/2025 – Jun/2026

- Worked in technical support, Linux and Proxmox environments, observability with Zabbix and Grafana, and web development, along with responsibilities involving networks and infrastructure. Progressively expanded responsibilities until promotion to the junior analyst position.

EDUCATION

UNICID | Technology Degree in Systems Analysis and Development | Jun/2026 – In progress

SENAI | Technical Diploma in Systems Development | Jul/2024 – Jun/2026

PROZ | Technical Diploma in Internet Computing | Jan/2023 – Dec/2024

SELECTED PROJECTS & INITIATIVES

APIsec | independent API security laboratory

Public FastAPI lab simulating BOLA, BFLA, and BOPLA (OWASP API Security Top 10:2023), comparing vulnerable versus protected behavior. Pytest, Ruff, Bandit, GitHub Actions, Docker, and Markdown/JSON evidence reports. Isolated test scenarios and synthetic data; no testing of third-party systems. github.com/CarlossgLuz/APIsec-LabTest

Open-Vaultin | AI Agent Harness Governance | open source

Continuously evolving independent open-source Python project (Early V1). Local-first agent harness governance layer: agent/skill registries, policies, task routing with JEV/TypeSafe decision model and deterministic fallback, Codex lifecycle hooks, durable execution ledger, evidence, Git-versioned knowledge, and MCP integration. The host client retains the primary agent loop; enforcement depends on its capabilities. github.com/CarlossgLuz/Open-Vaultin

Automated release QA system | internal initiative

Developing a pre- and post-release validation solution for platform features, integrations, permissions, and pipelines via APIs, with controlled runs, evidence collection, and traceability.

SAST tool benchmarking

Building controlled scenarios using references such as the OWASP Benchmark to assess coverage, accuracy, false positives, and false negatives for comparative testing.

TECHNICAL SKILLS

AppSec / DevSecOps: ASPM, SAST, SCA, DAST, Container Security, Secrets Scanning, SBOM, Secure SDLC, vulnerability management, supply chain security, RBAC.

Security analysis: OWASP Top 10, OWASP API Security Top 10, NVD, CVE/CWE, CVSS, GitHub Advisory Database; BOLA/BFLA/BOPLA authorization testing.

Tools: Sonatype Nexus Repository/Lifecycle/Firewall, XGuardian, Xygeni, Semgrep, OWASP ZAP, Gitleaks, Dependabot, Ruff, Bandit, Pytest.

AI / automation: AI Agent Harness Governance, agents/skills, JEV/TypeSafe, routing and fallback, MCP, APIs, execution ledgers, CI/CD.

Software / operations: Python, FastAPI, JS/TS, React/Next.js, SQL, Git, GitHub Actions, GitLab CI/CD, Linux, Docker, AWS/Azure, Proxmox, Zabbix/Grafana.

CERTIFICATIONS & LANGUAGES

Microsoft Azure Fundamentals (AZ-900) | Feb/2026 • Scrum Foundation Professional Certification (SFPC) | Oct/2024

English: B2 (Upper-Intermediate) | technical documentation and vendor meetings; continuing development.